

IAM Access Risk Audit Report

Prepared by: Senior IAM & GRC Security Auditor

Classification: Confidential – Internal Use Only

Review Scope: Automated Access Review – Identity & Access Management Controls

Applicable Industries: Financial Services / Healthcare

Executive Summary

The following findings were identified during an automated access review of user accounts and entitlements across in-scope systems. Four (4) access risk exceptions were detected, comprising one (1) Critical, one (1) High, and two (2) Medium severity findings. Each finding represents a control deficiency with potential exposure to unauthorized access, regulatory non-compliance, and reputational risk. Immediate remediation is recommended for Critical and High findings. Medium findings should be addressed within the organization's standard remediation SLA for access governance.

Detailed Findings

FINDING: [CRITICAL] — mgarcia

RISK:

User account `mgarcia`, affiliated with the Finance department in an Analyst role, remains active within the system despite the user's employment having been terminated. This represents a direct failure in the organization's joiner-mover-leaver (JML) process, specifically the offboarding lifecycle control. Active accounts belonging to terminated individuals pose one of the most severe identity-related risks, as these credentials may be exploited by the former employee, leveraged in credential stuffing attacks, or used by malicious insiders who retain knowledge of the account. The absence of timely deprovisioning indicates a breakdown in the coordination between Human Resources, IT, and system administrators, and suggests that automated offboarding workflows either do not exist or are not functioning as intended.

IMPACT:

From a business perspective, this finding exposes the organization to unauthorized access to sensitive financial data, potential fraud, and intellectual property theft. In a banking or healthcare environment, Finance department access typically encompasses general ledger systems, payment processing platforms, and financial reporting tools — all of which carry significant data sensitivity. From a compliance standpoint, failure to promptly revoke access for terminated users constitutes a direct violation of access management requirements under multiple regulatory frameworks. This finding would likely result in an audit exception or finding in a SOC 2 Type II examination and could trigger regulatory scrutiny under PCI-DSS and HIPAA audit cycles. Depending on jurisdictional requirements, prolonged retention of active terminated accounts may also implicate data privacy obligations under applicable law.

REMEDIATION:

1. Immediate (Within 24 Hours): Disable and lock the `mgarcia` account across all in-scope systems. Do not delete the account pending forensic review.
2. Short-Term (Within 72 Hours): Conduct a forensic access log review to determine whether the account has been accessed since the date of termination. Document findings and escalate to the Security Operations Center (SOC) if any post-termination access activity is identified.
3. Process Remediation (Within 30 Days): Audit the end-to-end offboarding workflow to identify the specific control failure that permitted the account to remain active. Implement automated deprovisioning triggers that are initiated upon HR system termination events, with a target SLA of account suspension within one (1) business day of termination.
4. Governance: Introduce a weekly reconciliation report comparing HR termination records against active directory and system accounts to serve as a compensating detective control.

FRAMEWORKS:

| Framework | Control Reference | Requirement |

|---|---|---|

| NIST 800-53 Rev. 5 | AC-2(f), AC-2(3) | Account management; disable accounts upon termination |

| PCI-DSS v4.0 | Requirement 7.3.3, 8.3.5 | Remove or disable inactive/terminated user accounts promptly |

| SOC 2 (Trust Services Criteria) | CC6.2, CC6.3 | Logical access provisioning and deprovisioning controls |

| HIPAA Security Rule | 45 CFR §164.308(a)(3)(ii)(C) | Termination procedures; revoke access upon workforce member departure |

FINDING: [HIGH] — rlee

RISK:

User `rlee`, classified as a Contractor within the Finance department, has been granted Privileged access to in-scope systems. Privileged access — defined as access rights that extend beyond standard user entitlements and may include administrative functions, elevated data permissions, or the ability to modify system configurations — should be tightly controlled and granted only where there is a clearly documented and approved business justification. The assignment of privileged access to a contractor represents a significant violation of the principle of least privilege (PoLP) and separation of duties. Contractors, by nature of their transient engagement, variable oversight, and typically less stringent vetting processes compared to full-time employees, represent an elevated risk vector when granted elevated system access. This finding suggests that either the role provisioning process lacks sufficient compensating controls for non-employee access, or that access entitlements were not properly reviewed upon or after onboarding.

IMPACT:

Privileged access within a Finance department system in a banking or healthcare organization can provide a contractor with the ability to access, modify, or exfiltrate sensitive financial records, payment data, or protected health information (PHI). The business risk includes potential fraud, data manipulation, and unauthorized data disclosure. From a compliance perspective, granting contractor accounts privileged access without documented justification, formal approval, enhanced monitoring, and periodic recertification represents a direct deficiency against access control standards. This finding would likely be flagged as a significant exception during a PCI-DSS assessment, particularly given the Finance department's probable proximity to cardholder data environments (CDE). It also undermines the organization's ability to demonstrate effective access governance under SOC 2 criteria.

REMEDIATION:

1. Immediate (Within 48 Hours): Initiate an emergency access review for `rlee` to validate whether privileged access was intentionally provisioned and whether a current, approved business justification exists.
2. Short-Term: If no valid justification exists or approval cannot be confirmed, downgrade `rlee`'s access level to Standard, consistent with the organization's baseline contractor access policy, and document the remediation action.
3. If Justification Exists: Ensure formal written approval from a system owner and data owner is on file, that the access is time-bound to the contract duration, and that enhanced monitoring and session logging are enabled for the account.
4. Process Remediation (Within 30 Days): Establish or reinforce a policy prohibiting the provisioning of privileged access to contractors without documented risk acceptance, multi-level approval, and quarterly recertification. Implement preventive controls in the provisioning workflow to flag contractor accounts requesting privileged roles for mandatory approval escalation.
5. Monitoring: Enable privileged access session monitoring and alerting for `rlee` retroactively, pending access review completion.

FRAMEWORKS:

| Framework | Control Reference | Requirement |

|---|---|---|

| NIST 800-53 Rev. 5 | AC-2, AC-6, AC-6(5) | Least privilege; privileged accounts — restrictions on access |

| PCI-DSS v4.0 | Requirement 7.2.2, 8.2.2 | Access assignment aligned to job function; restrict privileged access |

| SOC 2 (Trust Services Criteria) | CC6.3, CC6.6 | Logical access restrictions; third-party and contractor access controls |

| HIPAA Security Rule | 45 CFR §164.308(a)(3), §164.308(a)(4) | Workforce access management; information access management |

FINDING: [MEDIUM] — tjones

RISK:

User `tjones`, a Manager within the HR department, has not logged into their account for a period exceeding ninety (90) days, meeting the organization's threshold for classification as a dormant or inactive account. Dormant accounts represent an exploitable attack surface, as they are frequently overlooked during routine access reviews and may not be subject to the same level of monitoring as actively used accounts. An unused account that retains valid credentials and active entitlements can be leveraged by an external threat actor following credential compromise, or by an internal actor seeking to operate under a less scrutinized identity. The HR department context amplifies this risk, as HR systems typically contain sensitive employee personally identifiable information (PII), compensation data, performance records, and in healthcare environments, may interface with systems containing workforce health information.

IMPACT:

The continued existence of dormant accounts without review or remediation reflects a deficiency in the organization's periodic access recertification program. From a business perspective, an HR Manager-level account carries entitlements that may include access to sensitive personnel records and HR management system functions. Unauthorized access to such data could result in regulatory penalties under applicable privacy laws, workforce disruption, and reputational harm. From a compliance standpoint, this finding indicates that the organization's access recertification controls may not be operating effectively to identify and address stale entitlements in a timely manner, which is a commonly tested area in SOC 2 Type II audits and NIST-aligned security assessments.

REMEDIATION:

1. Short-Term (Within 5 Business Days): Contact the account owner (`tjones`) and their direct supervisor to confirm whether the account is still required and whether the inactivity is legitimate (e.g., extended leave).
2. If Account Is Required: Reactivate with a mandatory password reset and enforce multi-factor authentication (MFA) at next login. Document the business justification for retention.
3. If Account Is No Longer Required: Disable and deprovision the account promptly, following the organization's standard offboarding or access removal procedures.

4. Process Remediation: Ensure dormant account detection is incorporated into the quarterly access recertification cycle. Implement automated controls to disable accounts that have not been accessed within a defined threshold (recommended: 60–90 days) pending manager review.

FRAMEWORKS:

| Framework | Control Reference | Requirement |

|---|---|---|

| NIST 800-53 Rev. 5 | AC-2(3), IA-4(e) | Disable inactive accounts; identifier management |

| PCI-DSS v4.0 | Requirement 8.2.6 | Remove or disable inactive user accounts within 90 days |

| SOC 2 (Trust Services Criteria) | CC6.2, CC6.3 | Access provisioning and periodic recertification controls |

| HIPAA Security Rule | 45 CFR §164.308(a)(5)(ii)(C) | Log-in monitoring; review of access activity |

FINDING: [MEDIUM] — hkim

RISK:

User `hkim`, a Contractor within the Finance department with Standard-level access, has not authenticated to their account for a period exceeding ninety (90) days, qualifying this account as dormant under the organization's access governance policy. This finding is particularly noteworthy given the dual risk factors associated with this account: the user is an external contractor (non-employee) and the account resides within the Finance department. Contractor accounts are inherently time-limited in nature and should be tied directly to active engagement periods. An inactive contractor account suggests either that the engagement has concluded without triggering a formal offboarding action, or that the contractor's access was provisioned without a defined expiration date. Either scenario reflects a gap in the contractor access lifecycle management process.

IMPACT:

Dormant contractor accounts in the Finance department expose the organization to unauthorized access to financial systems and sensitive data by individuals who may no longer have a current business need or active contractual relationship with the organization. Unlike full-time employee dormancy, which may be attributable to leave or role transition, contractor inactivity over 90 days strongly implies that the engagement may have lapsed. Retaining active credentials for potentially off-boarded contractors is a direct compliance gap, particularly under PCI-DSS, which mandates timely removal of inactive accounts and requires that third-party access be managed with documented controls. This finding may also suggest that contractor access agreements lack enforceable expiration and review provisions.

REMEDIATION:

1. Short-Term (Within 5 Business Days): Verify with the Finance department and Procurement/Vendor Management whether `hkim`'s contract is currently active. Cross-reference the contractor's system access provisioning date against contract start and end dates.
2. If Contract Is Active: Confirm current business need, require re-authentication with mandatory password reset and MFA enforcement, and establish a formal access expiration date aligned with the contract end date.
3. If Contract Has Expired or Is Inactive: Immediately disable and deprovision the `hkim` account. Conduct a review of access logs from the period of inactivity to confirm no unauthorized usage occurred.
4. Process Remediation (Within 30 Days): Implement a contractor access governance policy requiring all contractor accounts to be provisioned with a hard expiration date that does not exceed the contract end date. Establish automated workflows to disable contractor accounts at contract expiry and trigger notification to system owners for review if activity ceases for 30 or more days.

FRAMEWORKS:

| Framework | Control Reference | Requirement |

|---|---|---|

| NIST 800-53 Rev. 5 | AC-2(2), AC-2(3), PS-7 | Non-organizational users; account inactivity; third-party personnel security |

| PCI-DSS v4.0 | Requirement 8.2.6, 8.6.1 | Disable inactive accounts; manage third-party/vendor access |

| SOC 2 (Trust Services Criteria) | CC6.2, CC6.3, CC9.2 | Access controls; vendor and third-party management |

| HIPAA Security Rule | 45 CFR §164.308(a)(3)(ii)(C), §164.308(b) | Access termination; business associate and contractor oversight |

Summary Risk Register

| Finding | User | Severity | Department | Status | Recommended Action |

|---|---|---|---|---|---|

| Terminated user — active record | mgarcia | ■ Critical | Finance | Open | Immediate account disable + forensic review |

| Contractor with privileged access | rlee | ■ High | Finance | Open | Emergency access review + privilege reduction |

| Dormant account (90+ days) | tjones | ■ Medium | HR | Open | Confirm status + disable or recertify |

| Dormant contractor account (90+ days) | hkim | ■ Medium | Finance | Open | Confirm contract status + disable or recertify |

Auditor Recommendations — Systemic Controls

Beyond individual finding remediation, the auditor recommends the following systemic improvements to reduce recurring IAM access risk exposure:

1. Implement an Automated JML Workflow: Integrate HR systems with identity governance platforms to trigger real-time provisioning, modification, and deprovisioning actions based on workforce lifecycle events.
2. Enforce Contractor Access Expiration Policies: All non-employee accounts should carry a mandatory hard expiration date at provisioning, with no exceptions without documented and approved business justification.
3. Establish Quarterly Access Recertification: Formalize a recertification program requiring system owners and managers to review and certify all user entitlements on a minimum quarterly basis.
4. Privileged Access Management (PAM): Deploy a PAM solution to govern, monitor, and record all privileged access sessions, with role-based approval workflows preventing contractor accounts from receiving privileged entitlements without escalated authorization.
5. Dormant Account Automation: Configure identity governance tooling to automatically flag and suspend accounts exceeding the organization's defined inactivity threshold, with notification to system owners for prompt review.

This report contains confidential audit findings intended solely for the use of the organization's management, IT security team, and applicable compliance stakeholders. Findings should be tracked to closure in the organization's GRC platform with assigned owners and target remediation dates.